

Lab 2: Data Access Decision Simulator

Company: EduConnect Rwanda — an ed-tech platform serving 50,000+ students across all five provinces

Role: DevOps Engineer, EduConnect Rwanda

Governing law: Rwanda's Law N° 058/2021 relating to the Protection of Personal Data and Privacy, supervised by the National Cyber Security Authority (NCSA)

Status: Required Lab (replacing the earlier, non-source-based "Data Cleansing Challenge" placeholder)

1. Data Classification Policy

EduConnect Rwanda classifies data into three tiers:

- **PUBLIC:** Marketing materials, public course catalogs.
- **INTERNAL:** Aggregated analytics, internal reports.
- **CONFIDENTIAL:** Student PII, grades, payment information.

2. The Scenario

It's Monday morning. Three data-access requests have arrived in the ticketing system. Each is resolved below against the classification policy, the principle of least privilege, and Rwanda's Law N° 058/2021.

3. Request 1 — Marketing Campaign

From: Diane Uwimana, Marketing Manager

Request: "I need the full student database (names, emails, phone numbers, course enrollments) to launch our new referral campaign. This is urgent — campaign starts Friday!"

Data classification involved: Email addresses (CONFIDENTIAL), Names (INTERNAL), Enrollments (INTERNAL)

Current access level: Diane has INTERNAL access only.

Decision: Conditionally Approve

Lifecycle Stage: Use (an already-collected dataset is being repurposed for a new use, not newly created, stored, or shared externally)

Justification

- Diane's INTERNAL clearance does not cover CONFIDENTIAL fields — email addresses are explicitly classified CONFIDENTIAL, so the request **as written cannot be granted in full**. Approving unrestricted access to the entire student database, including emails, would breach the least-privilege principle: marketing needs enough data to run a referral campaign, not the complete CONFIDENTIAL record set.
- Under Law N° 058/2021, processing personal data for a new purpose (marketing) beyond the purpose it was originally collected for (course delivery) requires a lawful basis for that new purpose — typically consent or a compatible-purpose justification — not simply an internal request being "urgent."
- The deadline pressure ("starts Friday") is a business constraint, not a legal or security justification, and must not be allowed to compress the review below the minimum needed to check classification and purpose compatibility.

Safeguards for Conditional Approval

1. Marketing receives a **derived, minimal dataset**: student names and enrollment status only, for currently-enrolled students who have not opted out of marketing communications — email addresses are **excluded** from the direct export.
2. Any actual email send is executed by a system that already holds legitimate CONFIDENTIAL-tier access (e.g. the platform's own notifications service) on marketing's behalf, so raw email addresses never leave CONFIDENTIAL-tier systems into Diane's hands.
3. The referral campaign copy and data use are logged and time-boxed to the campaign period; access is revoked automatically afterward rather than left open-ended.

Who Else Must Be Consulted

- The Data Protection Officer / privacy lead, to confirm the marketing use is compatible with the original collection purpose and that an opt-out mechanism already exists for students who don't want marketing contact.
- The platform/security team, to implement the notification-service workaround in point 2 above rather than a direct data export.

Action Steps

1. Deny the literal request for a full database export.
 2. Approve a minimal, opted-in-only derived dataset for the campaign, delivered without raw email addresses.
 3. Route actual email delivery through the CONFIDENTIAL-tier notification service.
 4. Log the access grant with a campaign end date and automatic revocation.
-

4. Request 2 — Analytics Partnership

From: Eric Nkurunziza, Head of Product

Request: "I've signed a partnership with DataInsights Inc. (US-based) to analyze our student learning patterns. They need access to our AWS database to run their algorithms. Login credentials attached."

Data classification involved: Student activity logs (INTERNAL), Student profiles (CONFIDENTIAL)

Compliance note: EduConnect Rwanda is subject to Rwanda's Law N° 058/2021.

Decision: Deny (as requested), pending a compliant redesign

Lifecycle Stage: Share (this is a cross-border data-sharing/transfer event, the most tightly controlled stage of the lifecycle)

Legal / Compliance Red Flags

1. **Direct database credentials handed to a third party is a security failure on its own**, independent of data protection law — it gives DataInsights Inc. unbounded access to *everything* in that database, including CONFIDENTIAL student profiles that have nothing to do with "learning patterns," not a scoped extract.
2. **Cross-border transfer of personal data out of Rwanda** to a US-based processor is subject to Rwanda's Law N° 058/2021's rules on international data transfers, which generally require either an adequacy-type safeguard, a data transfer agreement with appropriate contractual protections, or another recognized legal transfer mechanism — a signed *business* partnership agreement alone does not satisfy this on its own.
3. **No evidence of a Data Processing Agreement (DPA)** between EduConnect Rwanda (controller) and DataInsights Inc. (processor) defining purpose limitation, security obligations, breach notification, and data deletion at contract end.
4. **No indication students were informed or consented** to their data being analyzed by an external, foreign company — this is a new processing purpose and a new recipient, both of which typically require a fresh legal basis under the Law.

Controls Required Before Any Sharing Can Proceed

- Replace direct database credentials with a **scoped, purpose-built data extract or API** exposing only anonymized/pseudonymized activity logs needed for the learning-pattern analysis — CONFIDENTIAL profile fields (names, contact info, payment data) should not be in scope at all if the stated purpose is behavioral analysis.
- Execute a formal **Data Processing Agreement** with DataInsights Inc. covering purpose limitation, security measures, sub-processor restrictions, breach notification timelines, and end-of-contract deletion.
- Establish the **cross-border transfer safeguard** required under Rwanda's Law N° 058/2021 (e.g., standard contractual clauses or an equivalent mechanism) before any data leaves Rwandan infrastructure.

- Update EduConnect Rwanda's privacy notice and, where the processing purpose is not already covered by the original terms students agreed to, obtain the appropriate consent or confirm an alternative lawful basis.

Required Documentation

- Signed DPA with DataInsights Inc.
- Records of the legal transfer mechanism used for the cross-border transfer.
- A data protection impact assessment (DPIA) given the volume of data and cross-border, third-country processing involved.
- Updated privacy notice reflecting the new processing activity and recipient.

Action Steps

1. Immediately revoke the shared database credentials — this should never have been sent.
2. Deny the request in its current form and notify Eric that a compliant path exists but requires the controls above.
3. Engineering builds a scoped, anonymized extract/API for the specific learning-pattern fields needed.
4. Legal/DPO executes a DPA and puts a cross-border transfer safeguard in place.
5. Only after 1–4 are complete, provision the scoped access.

5. Request 3 — Archive & Deletion

From: Claudine Mukamana, Customer Support Lead

Request: "A student, Eric Habimana, has requested full deletion of his account and all associated data per his right to erasure. He completed his last course 6 months ago and has no pending payments. How should I proceed?"

Data classification involved: All student data (CONFIDENTIAL)

Current status: Account inactive, no outstanding obligations.

Decision: Approve, with a limited retained subset

Lifecycle Stage: Destroy (with a brief transition through Archive for the narrow subset that must legally survive deletion)

Can the Request Be Fulfilled?

Yes, substantially — Eric's request can be honored for the vast majority of his data. Full, unconditional deletion of every record is not possible where a separate legal retention obligation exists (e.g.,

financial/tax record-keeping for completed transactions), but that exception is narrow and must not be used to justify keeping more than the law actually requires.

Legal Obligations Under Rwanda's Law N° 058/2021

- Data subjects have a right to request erasure of their personal data, and the controller must act on qualifying requests once the original purpose for holding the data (here, active course access) no longer applies.
- That right yields to a genuine legal obligation to retain specific records (financial/tax record-keeping requirements), which take precedence over the erasure request **only for those specific records**, not for the account as a whole.

What Can Be Retained, and Why

Data	Retain or Delete	Reason
Profile data (name, contact info, learning progress, course content interactions)	Delete	No ongoing legal basis to retain once the account is inactive and the student has requested erasure
Payment/transaction records for completed course purchases	Retain , for the statutory financial record-keeping period	Required by financial/tax regulation independent of the data protection law
A minimal deletion-request log (that Eric requested erasure, and when it was completed)	Retain , indefinitely or per internal audit policy	Needed to demonstrate compliance with the erasure request itself, per the Law's accountability principle

Process Customer Support Should Follow

1. **Verify identity** — confirm the request genuinely came from Eric Habimana (e.g., via the email/phone on file), not a third party impersonating him.
2. **Confirm no active obligation** — checked here: account inactive 6 months, no pending payments.
3. **Delete profile and learning-activity data** across all systems, including backups where feasible within a reasonable timeframe.
4. **Retain only the financial records** required by law, clearly tagged with the retention basis and an automatic deletion date once that period expires.
5. **Log the erasure request and completion date** for audit purposes.
6. **Confirm completion to Eric in writing**, specifying what was deleted and what narrow subset was retained and why.

Draft Response

"Dear Eric, your request has been received and processed. Your profile and learning-activity data have been deleted. We are required to retain your payment records for [retention period] under applicable financial regulations; these will be deleted automatically once that period ends. Thank you for having been part of EduConnect Rwanda."

6. Cross-Request Comparison

Request	Lifecycle Stage	Decision	Core Principle Applied
1. Marketing campaign	Use	Conditional approval	Least privilege + purpose compatibility
2. Analytics partnership	Share (cross-border)	Deny pending redesign	Data minimization + lawful cross-border transfer mechanism
3. Archive & deletion	Destroy (with narrow Archive exception)	Approve, partial retention	Right to erasure vs. legal retention obligation

7. Key Takeaways

- **"Urgent" is not a security or legal category.** Requests 1 and 2 both arrived with time pressure attached, and in both cases the correct response was to find the compliant version of what was being asked, not to skip the review because a deadline was close.
- **Classification tier determines what's grantable, not what's requested.** A requester's role and clearance should bound the response independent of how the request itself is worded — Diane asked for "the full database" but her INTERNAL clearance, and the actual campaign need, both point to a much smaller grant.
- **Cross-border sharing is where the most controls stack up at once:** classification, purpose limitation, a processor agreement, and Rwanda's international-transfer safeguard all have to be satisfied together before Request 2 can proceed — this is deliberately the highest-friction lifecycle stage.
- **Erasure rights and retention obligations are not actually in conflict** once the data is separated at the field level — Eric's request and EduConnect Rwanda's financial record-keeping duty can both be fully satisfied simultaneously, because they apply to different subsets of his data, not the account as an undifferentiated whole.